DOCUMENT 3 OF 3

DATA PROCESSING AGREEMENT

Controller-to-processor terms under Article 28 of the GDPR for cloud services

between

[PROVIDER LEGAL NAME], [registered office / company number]
(the Provider)

and

[CUSTOMER LEGAL NAME], [registered office / company number]
(the Customer)

Agreement reference: [REF] | Effective Date: [DATE] | Version: [1.0]

Forms part of the Cloud Services Master Services Agreement (Document 1). It is a bespoke DPA drafted to contain every element required by Article 28(3) GDPR; the parties may instead adopt the Commission's Article 28 standard contractual clauses (Implementing Decision (EU) 2021/915). Where Personal Data is transferred outside the EEA, Annex IV applies. Square brackets mark items to be completed. This is a drafting aid, not legal advice.

Contents

Part A. Article 28 Compliance Map 3

Part B. Data Processing Agreement 4

1. Definitions and Interpretation . . . 4
2. Subject Matter, Duration, Nature and Purpose . . . 4
3. Documented Instructions and Roles . . . 4
4. Confidentiality and Personnel . . . 5
5. Security of Processing . . . 5
6. Sub-processors . . . 5
7. Assistance with Data Subject Rights . . . 6
8. Personal Data Breach . . . 6
9. Assistance with DPIAs, Prior Consultation and Security . . . 7
10. International Transfers . . . 7
11. Information, Audits and Inspections . . . 8
12. Deletion and Return . . . 8
13. Records and Cooperation . . . 8
14. Liability . . . 9
15. Term, Changes and General . . . 9

Annex I. Description of the Processing 10

Annex II. Technical and Organisational Measures 11

Annex III. Authorised Sub-processors 12

Annex IV. International Transfers - Transfer Mechanisms and SCC Elections 13

Part A. Article 28 Compliance Map

Article 28(3) GDPR requires that processing by a processor be governed by a contract or other legal act that is binding on the processor, sets out the subject matter, duration, nature and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller, and that stipulates the points below. Article 28(9) requires the contract to be in writing, including in electronic form. The table maps each requirement to this DPA.

GDPR requirement	Where addressed
Art. 28(3) - subject matter, duration, nature, purpose, personal data types, data-subject categories	Clause 2; Annex I
Art. 28(3)(a) - process only on documented instructions, including on transfers; inform controller of legal requirement to process	Clause 3; Clause 10
Art. 28(3)(b) - persons authorised to process are committed to confidentiality	Clause 4
Art. 28(3)(c) and Art. 32 - appropriate technical and organisational security measures	Clause 5; Annex II
Art. 28(3)(d), 28(2), 28(4) - conditions for engaging another processor; flow-down; initial processor remains liable	Clause 6; Annex III
Art. 28(3)(e) - assistance with data-subject requests (Arts. 12-23)	Clause 7
Art. 28(3)(f) - assistance with Arts. 32-36 (security, breach notification, DPIA, prior consultation)	Clauses 8 and 9
Art. 28(3)(g) - deletion or return of data at the controller's choice at end of services	Clause 12
Art. 28(3)(h) - information, audits and inspections; Art. 28(3) final subparagraph - inform of infringing instructions	Clauses 11 and 3.3
Art. 30(2) - processor's record of processing	Clause 13
Art. 33(2) - processor notifies controller of a personal data breach without undue delay	Clause 8
Arts. 44-49 - transfers of personal data to third countries	Clause 10; Annex IV
Art. 82 - liability and compensation; Art. 28(10) - processor determining purposes becomes controller	Clauses 14 and 3.5

Roles in the cloud service models

Service Model	Typical processing by the Provider	Practical points for the DPA
IaaS (rented kitchen)	Stores and moves data the Customer places on infrastructure; usually no routine visibility of content	Provider still a processor if it can access or is responsible for the storage; the Customer controls encryption and access, so security measures are shared (MSA Schedule 3)
PaaS (equipped kitchen)	Hosts the Customer's application and databases; may access logs and diagnostics	Define access to logs and support access; sub-processors for managed services; deletion of databases and snapshots
SaaS (ready meal)	Processes content through the application: user data, documents, communications	Full Annex I description of categories; Provider support access; tenant separation; sub-processors; export and deletion

Drafting note: *Controller or processor is a question of fact (EDPB Guidelines 07/2020). A cloud provider that decides on its own the purposes (for example, using content to train its own models or for analytics) acts as a controller for that processing, and Art. 28(10) makes it responsible as controller. This DPA therefore prohibits such use (Clause 3.4).*

Part B. Data Processing Agreement

This Data Processing Agreement (**DPA**) is entered into on [DATE] between [CUSTOMER LEGAL NAME] (the **Controller**, or the Customer acting on behalf of its Affiliates and, where relevant, as processor on behalf of its own controllers) and [PROVIDER LEGAL NAME] (the **Processor**, or the Provider), and forms part of the Cloud Services Master Services Agreement dated [DATE] (the **MSA**).

1. Definitions and Interpretation

1.1 In this DPA, the terms **controller, processor, data subject, personal data, personal data breach, processing, supervisory authority, special categories of personal data** and **pseudonymisation** have the meanings in the GDPR. Other capitalised terms have the meaning in the MSA.

1.2 **GDPR** means Regulation (EU) 2016/679. **Applicable Data Protection Law** means the GDPR, national laws implementing or supplementing it, and (to the extent applicable) the UK GDPR and Data Protection Act 2018 and the Swiss Federal Act on Data Protection. **Customer Personal Data** means personal data in Customer Data that the Provider processes on behalf of the Customer under the MSA. **Sub-processor** means any processor engaged by the Provider (or by another Sub-processor) that processes Customer Personal Data. **EEA** means the European Economic Area. **SCCs** means the standard contractual clauses annexed to Commission Implementing Decision (EU) 2021/914. **Restricted Transfer** means a transfer of Customer Personal Data to a country outside the EEA that is not subject to an adequacy decision under Article 45 GDPR, or onward transfer thereof.

1.3 This DPA applies for as long as the Provider processes Customer Personal Data. If there is a conflict between this DPA and the MSA (or any other agreement) about the processing of Customer Personal Data, this DPA prevails. If there is a conflict between this DPA and the SCCs, the SCCs prevail.

2. Subject Matter, Duration, Nature and Purpose

2.1 The subject matter, nature and purpose of the processing, the types of Customer Personal Data and the categories of data subjects are set out in Annex I. The duration of the processing is the Term of the MSA plus the period needed for the exit, return and deletion obligations in Clause 12.

2.2 The Customer instructs the Provider to process Customer Personal Data to provide the Services as described in the MSA and Annex I. The Customer is responsible for ensuring that the Annex I description is accurate and for updating it if the processing changes.

3. Documented Instructions and Roles

3.1 **Instructions.** The Provider shall process Customer Personal Data only on the Customer's documented instructions, including with regard to transfers of personal data to a third country or an international organisation, unless required to do so by Union or Member State law to which the Provider is subject; in that case the Provider shall inform the Customer of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest. (Art. 28(3)(a))

3.2 The MSA, this DPA, the Order Form, and the Customer's use and configuration of the Services constitute the Customer's complete and final documented instructions. Additional or alternative instructions must be consistent with the MSA and agreed under the change procedure in the MSA; the Provider may charge reasonable costs only if an instruction requires material additional work not required for the Services, and shall notify the Customer of any such charge beforehand.

3.3 **Infringing instructions.** The Provider shall immediately inform the Customer if, in its opinion, an instruction infringes the GDPR or other Union or Member State data protection law. The Provider may suspend the relevant processing until the Customer confirms or modifies the instruction. (Art. 28(3), final subparagraph)

3.4 **No independent purposes.** The Provider shall not process Customer Personal Data for its own purposes or those of any third party, including advertising, profiling, product improvement, or training of

machine-learning models, other than as stated in MSA Clause 10.4 in relation to its own controller processing of Service Data. The Provider shall not sell, rent or share Customer Personal Data.

3.5 If the Provider determines the purposes and means of processing Customer Personal Data in breach of this DPA, it shall be considered a controller in respect of that processing under Article 28(10) GDPR, without prejudice to the Customer's rights.

3.6 **Customer responsibilities.** The Customer is responsible for the lawfulness of its processing, including having a legal basis, providing notices to data subjects, ensuring that its instructions comply with law, and determining which data it places on the Services (including special categories of personal data, which the Customer may only upload if the Order Form permits it and Annex II measures are suitable).

3.7 **Controller affiliates and chains.** Where the Customer acts as a processor on behalf of a third-party controller, the Customer warrants that its instructions, including the appointment of the Provider as a sub-processor, have been authorised by the relevant controller, and that the terms of this DPA satisfy the obligations imposed on the Customer by that controller. The Provider shall give the Customer information needed to meet those obligations.

4. Confidentiality and Personnel

4.1 The Provider shall ensure that persons authorised to process Customer Personal Data (a) have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality, (b) process Customer Personal Data only on the Provider's instructions as documented under Clause 3 (Art. 29 GDPR), and (c) have received appropriate data-protection and security training. (Art. 28(3)(b))

4.2 The Provider shall restrict access to Customer Personal Data to personnel who need access to provide the Services, and shall maintain logs of such access in accordance with Annex II. The confidentiality obligation continues after the end of the personnel's engagement.

5. Security of Processing

5.1 The Provider shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, the nature, scope, context and purposes of processing, and the risks to the rights and freedoms of natural persons, as required by Article 32 GDPR. At a minimum, the measures in Annex II (and MSA Schedule 4) shall be implemented and maintained, including as appropriate: (a) pseudonymisation and encryption of personal data; (b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services; (c) the ability to restore availability of and access to personal data in a timely manner in the event of a physical or technical incident; and (d) a process for regularly testing, assessing and evaluating the effectiveness of the measures. (Art. 28(3)(c), Art. 32)

5.2 The Provider shall not materially diminish the overall level of protection in Annex II during the Term. It may update measures to reflect technological developments, provided that the resulting level of security is not lower. The Provider shall notify material changes.

5.3 The Customer is responsible for assessing whether the measures meet its requirements and for implementing the measures that the Shared Responsibility Matrix (MSA Schedule 3) places on it, including secure configuration, access control, and key management of resources it controls.

6. Sub-processors

6.1 **Authorisation.** [Option A - General written authorisation: The Customer gives general authorisation for the Provider to engage the Sub-processors listed in Annex III, and to add or replace Sub-processors in accordance with Clause 6.3.] [Option B - Specific authorisation: The Provider shall not engage any Sub-processor without the Customer's specific prior written authorisation.] (Art. 28(2))

6.2 **List.** Annex III lists each authorised Sub-processor, its location, the processing it performs, and the transfer mechanism (if any). The Provider shall keep a current list at [URL] and shall provide it on request, so that

the Customer can identify every processor and Sub-processor in the processing chain.

6.3 **Changes (Option A).** The Provider shall give the Customer at least [thirty (30)] days' prior written notice (by email to [address] and by notification in the service portal) of any intended addition or replacement of a Sub-processor, thereby giving the Customer the opportunity to object. If the Customer objects on reasonable data-protection grounds within [fifteen (15)] days of the notice, the Parties shall discuss in good faith. If the Provider cannot offer a reasonable alternative (such as continuing the Services without the new Sub-processor, or a different location) within [thirty (30)] days, the Customer may terminate the affected Services without penalty and with a pro-rata refund of prepaid Fees, with the exit rights in MSA Clause 22. The new Sub-processor may not process Customer Personal Data until the objection period expires or the objection is resolved.

6.4 **Flow-down.** Where the Provider engages a Sub-processor, it shall do so by a written contract imposing the same data-protection obligations as those in this DPA (including the Art. 28(3) obligations), in particular providing sufficient guarantees to implement appropriate technical and organisational measures, and shall ensure the Sub-processor's compliance. Where the Sub-processor involves a Restricted Transfer, the Provider shall put in place a valid transfer mechanism under Annex IV. The Provider shall provide the Customer, on request, with a copy of the relevant data-protection terms (commercial terms redacted). (Art. 28(4))

6.5 **Liability.** The Provider remains fully liable to the Customer for the performance of the Sub-processor's obligations and for its acts and omissions in relation to Customer Personal Data. (Art. 28(4))

6.6 **Emergency replacement.** The Provider may replace a Sub-processor on shorter notice where necessary to maintain security or continuity, provided it notifies the Customer promptly and the Customer retains its objection and termination rights under Clause 6.3.

> ***Drafting note:*** *EDPB Opinion 22/2024 (October 2024) stresses that controllers should be able to identify all processors and Sub-processors in the chain and obtain the underlying information; the Clause 6.2 list and the copy-on-request right in 6.4 support that. Note also that the Schrems II-era caution about onward transfers remains relevant for non-EEA Sub-processors.*

7. Assistance with Data Subject Rights

7.1 Taking into account the nature of the processing, the Provider shall assist the Customer by appropriate technical and organisational measures, insofar as possible, in fulfilling the Customer's obligation to respond to requests from data subjects exercising their rights under Chapter III GDPR (access, rectification, erasure, restriction, portability, objection, and rights regarding automated decisions). (Art. 28(3)(e))

7.2 The Provider shall provide self-service tools or functionality in the Services, to the extent available, for the Customer to access, correct, export, restrict and delete Customer Personal Data. Where the Customer cannot fulfil a request using the Services, the Provider shall provide reasonable assistance within [five (5)] working days.

7.3 If the Provider receives a request directly from a data subject relating to Customer Personal Data, it shall not respond (other than to confirm that the request relates to the Customer, if identified) and shall forward it to the Customer within [three (3)] working days, unless required by law.

8. Personal Data Breach

8.1 The Provider shall notify the Customer of any personal data breach (a Security Incident under the MSA involving Customer Personal Data) without undue delay, and in any event within [24 / 48] hours after becoming aware of it, so that the Customer can meet its obligation under Article 33(1) GDPR to notify the supervisory authority within 72 hours. (Art. 33(2))

8.2 The notification shall, to the extent known, describe: (a) the nature of the breach, including the categories and approximate number of data subjects and records concerned; (b) the name and contact details of the Provider's data-protection or security contact; (c) the likely consequences; and (d) the measures taken or proposed to address the breach and mitigate adverse effects. Where information cannot be provided at the

same time, it may be provided in phases without undue further delay.

8.3 The Provider shall promptly investigate, contain and remediate the breach, preserve relevant evidence, keep the Customer informed at least every [24] hours until resolved, provide a written report within [ten (10)] days, and cooperate with the Customer's notifications to supervisory authorities and data subjects. The Provider shall not notify any supervisory authority, data subject or the public of a breach affecting Customer Personal Data in a manner that identifies the Customer without the Customer's prior approval, unless required by law.

8.4 The Provider's notification or assistance is not an acknowledgment of fault or liability. The costs of the Provider's response are borne by the Provider to the extent the breach resulted from its breach of this DPA; the Customer bears the costs of its own notifications except as provided in MSA Clause 19.5.

9. Assistance with DPIAs, Prior Consultation and Security

9.1 Taking into account the nature of processing and the information available to it, the Provider shall assist the Customer in ensuring compliance with its obligations under Articles 32 to 36 GDPR, namely security of processing, breach notification and communication, data protection impact assessments, and prior consultation of the supervisory authority. (Art. 28(3)(f))

9.2 The Provider shall provide the information about the Services that the Customer reasonably needs to carry out a data protection impact assessment or a transfer impact assessment, including descriptions of processing operations, security measures, sub-processors, data locations, and government-access policies, and shall consult with the supervisory authority where required.

10. International Transfers

10.1 **Location.** The Provider shall process and store Customer Personal Data only in the Service Region stated in the Order Form. It shall not transfer, or permit access to, Customer Personal Data from outside the EEA (including remote access for support or administration) except on the Customer's documented instructions, which include the transfers described in Annex III and Annex IV, or where required by law as provided in Clause 3.1.

10.2 **Transfer mechanisms.** Any Restricted Transfer shall be made only on the basis of (in order of preference): (a) an adequacy decision under Article 45 GDPR covering the recipient (including, for recipients certified under the EU-US Data Privacy Framework, the Commission's adequacy decision of 10 July 2023, while it remains valid); (b) the SCCs, which are incorporated into this DPA as set out in Annex IV; or (c) another safeguard under Article 46 or a derogation under Article 49 only where the Customer has agreed in writing.

10.3 **Resilience to change.** If a transfer mechanism on which the Parties rely is invalidated, suspended or ceases to be applicable (including if the EU-US Data Privacy Framework adequacy decision is annulled or suspended), the Provider shall notify the Customer promptly and, automatically and without further agreement, the SCCs (or another valid mechanism) shall apply to the affected transfers from the date of invalidity, and the Parties shall cooperate on supplementary measures and, if necessary, suspension of the transfer. The Customer may terminate the affected Services without penalty if a lawful transfer cannot be maintained.

10.4 **Transfer impact assessment and supplementary measures.** The Provider warrants that it has assessed, and shall keep updated, the law and practice of each third country to which Customer Personal Data may be transferred or from which it may be accessed, including laws on government access, and that it has no reason to believe that they prevent it from fulfilling its obligations under this DPA and the SCCs. It shall provide the Customer with a copy of its transfer impact assessment on request and implement the supplementary measures described in Annex IV (including strong encryption with keys held in the EEA or by the Customer where agreed, pseudonymisation and access controls).

10.5 **Government access requests.** If the Provider receives a legally binding request from a public authority (including a judicial authority) for disclosure of Customer Personal Data, it shall: (a) review its legality and challenge it where there are reasonable grounds to conclude that it is unlawful under the law of the

requesting country, applicable international law or comity principles; (b) disclose the minimum amount of data permissible; (c) notify the Customer promptly, unless prohibited, and attempt to obtain a waiver of any prohibition; (d) provide the Customer with as much information as permitted; and (e) keep records of requests and responses. It shall not give any authority access to Customer Personal Data on a voluntary or generalised basis.

11. Information, Audits and Inspections

11.1 The Provider shall make available to the Customer all information necessary to demonstrate compliance with the obligations laid down in Article 28 GDPR, and shall allow for and contribute to audits, including inspections, conducted by the Customer or another auditor mandated by the Customer. (Art. 28(3)(h))

11.2 **Process.** The Provider shall first make available the most recent independent audit reports and certifications described in MSA Schedule 4 and respond to reasonable questionnaires within [thirty (30)] days. Where these are not sufficient to demonstrate compliance, or where a supervisory authority or competent regulator so requires, or following a personal data breach, the Customer (or its mandated auditor, bound by confidentiality) may audit the Provider's processing and relevant facilities and records on [thirty (30)] days' notice (shorter where required by a regulator or following a breach), during business hours, no more than [once] a year except as stated, with minimum disruption, and without access to other customers' data.

11.3 The Provider shall ensure equivalent audit rights regarding Sub-processors, directly or through reports and inspections, and shall exercise its own rights of audit of Sub-processors when the Customer reasonably requests. Each Party bears its own costs of audit, unless the audit reveals a material breach by the Provider, in which case the Provider reimburses the reasonable cost of the audit.

11.4 The Provider shall cooperate with supervisory authorities, including by responding to requests and making available personnel and records, and shall notify the Customer of any enquiry or inspection by a supervisory authority concerning Customer Personal Data, unless prohibited by law.

12. Deletion and Return

12.1 At the choice of the Customer, after the end of the provision of Services (or earlier on the Customer's instruction), the Provider shall delete or return all Customer Personal Data to the Customer, and delete existing copies, unless Union or Member State law requires storage of the personal data. The Customer shall indicate its choice in writing within [thirty (30)] days of the end of the Services; if it does not, the Provider shall make the data available for retrieval during the retrieval period under MSA Clause 22.5 and then delete it. (Art. 28(3)(g))

12.2 Return shall be in the structured, commonly used and machine-readable formats set out in MSA Schedule 5. Deletion from production systems shall be completed within [thirty (30)] days after the end of the retrieval period, and from backups and archives within [ninety (90)] days, using secure deletion methods in Annex II, and the Provider shall certify deletion in writing within [ten (10)] days of completion on request.

12.3 Where the Provider is required by law to retain any Customer Personal Data, it shall inform the Customer of the law and data concerned, ensure the confidentiality and security of the data, process it only as required by that law, and delete it once the retention period ends.

13. Records and Cooperation

13.1 The Provider shall maintain a record of all categories of processing activities carried out on behalf of the Customer containing the information in Article 30(2) GDPR (including the name and contact details of the Provider, each Customer, each Sub-processor, the categories of processing, transfers to third countries with their safeguards, and a general description of the security measures), and make it available to the supervisory authority and the Customer on request.

13.2 The Provider shall designate a data protection officer where required by Article 37 GDPR, and shall provide the details in Annex I. Where the Provider is not established in the Union and Article 3(2) applies, it shall appoint a representative under Article 27 and provide its details in Annex I.

13.3 The Parties shall cooperate on request with supervisory authorities in the performance of their tasks.

14. Liability

14.1 Each Party's liability under or in connection with this DPA is subject to the limitations in MSA Clause 19 (including the data protection super-cap in MSA Clause 19.3), except that nothing limits a Party's liability to data subjects under Article 82 GDPR.

14.2 Under Article 82 GDPR, a processor is liable for damage caused by processing only where it has not complied with obligations of the GDPR specifically directed to processors or where it has acted outside or contrary to lawful instructions of the controller. Where both Parties are responsible for the same damage to a data subject, each may be held liable for the entire damage; the Party that has paid full compensation may claim from the other the part corresponding to the other's responsibility for the damage (Art. 82(4)-(5)).

14.3 The Parties acknowledge that administrative fines imposed under Article 83 GDPR are imposed on the person responsible. As between the Parties, a Party that causes the other to incur a fine by breach of this DPA shall, to the extent permitted by law, reimburse it as set out in MSA Clause 18.2, subject to Clause 14.1.

15. Term, Changes and General

15.1 This DPA starts on the Effective Date of the MSA and continues until the Provider has deleted or returned all Customer Personal Data under Clause 12 (and, for obligations that by nature survive, afterwards).

15.2 The Provider may propose changes to this DPA that are required to comply with Applicable Data Protection Law, a decision of a supervisory authority or court, or a change in the standard contractual clauses. The Parties shall negotiate in good faith, and the changes take effect only when agreed in writing; the Customer shall not unreasonably refuse changes that are legally required.

15.3 If any provision is invalid, the rest is unaffected; the Parties shall replace it with a valid provision of similar effect. This DPA is governed by the law governing the MSA, save that the SCCs are governed by the law specified in Annex IV. Disputes are subject to the dispute-resolution provisions of the MSA, subject to the SCCs.

15.4 **UK and Switzerland.** Where Customer Personal Data subject to the UK GDPR or Swiss FADP is transferred, the UK International Data Transfer Addendum (or the UK International Data Transfer Agreement) and the Swiss modifications described in Annex IV apply.

Signed for and on behalf of [CUSTOMER LEGAL NAME] (Controller)	**Signed for and on behalf of [PROVIDER LEGAL NAME] (Processor)**
Signature: _____ Name: [NAME] Title: [TITLE] Date: [DATE]	Signature: _____ Name: [NAME] Title: [TITLE] Date: [DATE]

Annex I. Description of the Processing

Item	Details
Controller (data exporter)	[Customer legal name, address, contact details of data-protection officer / privacy lead]; role: controller [or processor]
Processor (data importer)	[Provider legal name, address]; contact: [name, position, email]; DPO: [details]; EU representative (if any): [details]
Subject matter	Provision of the cloud Services ([IaaS / PaaS / SaaS]) described in the Order Form
Nature of processing	Hosting, storage, retrieval, transmission, backup, replication, deletion, support and administration of the Services. [IaaS: storage and transmission of data placed by Customer; PaaS: also execution of applications and database operations; SaaS: operation of the application on Customer content.]
Purposes	To provide the Services to the Customer; to secure the Services; to provide support requested by the Customer; to comply with the Customer's documented instructions
Duration	Term of the MSA plus the retrieval and deletion periods in MSA Clause 22 and DPA Clause 12
Categories of data subjects	[Customer's employees and contractors; customers and prospects; end users of the Customer's services; suppliers and their staff; other: _____]
Types of personal data	[Identification and contact data; account and authentication data; usage and location data; communications content; financial and transaction data; HR data; other: _____]
Special categories / sensitive data	[None permitted unless ticked:] health / biometric / genetic / racial or ethnic origin / political opinions / religious beliefs / trade-union membership / sex life or orientation / criminal convictions data (Art. 10). Additional safeguards: [strict access control, encryption, restricted purposes, logging]
Frequency of transfer	Continuous for the Term
Retention	Until deletion by the Customer or at end of services per Clause 12
Competent supervisory authority	[Authority of the Member State where the Customer is established, or where its EU representative is, as per Clause 13 of the SCCs]

Annex II. Technical and Organisational Measures

Measures implemented by the Provider (including the measures to ensure the security of the data, per Article 32 GDPR). Measures in MSA Schedule 4 apply in addition.

Measure	Description (complete to reflect the actual service)
Pseudonymisation and encryption	Encryption of Customer Personal Data in transit (TLS 1.2+) and at rest (AES-256 or equivalent); key management with segregation of duties; customer-managed keys [available / required for ...]; pseudonymisation of data used for support or diagnostics where practicable
Confidentiality - access control	Role-based, least-privilege access; MFA on all administrative access; privileged access management with approval and session recording; quarterly access reviews; automatic revocation on leaving; no routine provider access to content
Confidentiality - separation	Logical tenant isolation; separate production and non-production environments; no live Customer Personal Data in testing
Integrity	Input and change control; integrity checks (checksums, hashing); tamper-resistant logs; change-management process
Availability and resilience	Redundant power, cooling and network; multi-zone architecture; DDoS protection; capacity management; backups per the SLA (RPO / RTO); disaster-recovery tests at least annually
Resilience of systems	Anti-malware; vulnerability management (critical patches within [7] days); hardening standards; penetration tests at least annually by independent parties
Restoring availability	Documented procedures and tested restoration of data from backups; business continuity plan
Testing and evaluation	ISMS certified to ISO/IEC 27001; SOC 2 Type II; internal audits; management review; risk assessments at least annually
Incident response	Documented incident-response process; 24x7 monitoring; breach notification as per Clause 8
Physical security	Controlled and logged access to facilities; CCTV; visitor management; environmental controls
Personnel	Background checks (where lawful); confidentiality undertakings; mandatory annual security and privacy training
Sub-processor management	Pre-contract due diligence and security review; contractual flow-down; periodic review
Deletion	Secure erasure in accordance with NIST SP 800-88 or equivalent; cryptographic erasure; deletion certificates
Data minimisation and by-design measures	Collection limited to what the Services require; default settings favour privacy; retention limits; logging avoids content where practicable
Assistance with data-subject rights	Self-service export, rectification and deletion tools; support-ticket procedure with response time of [5] working days

Annex III. Authorised Sub-processors

The Customer has authorised the Sub-processors below (Clause 6.1). The current list is maintained at [URL].

Sub-processor (legal name, address)	Processing / services	Location(s) of processing	Transfer mechanism (if outside EEA)	Contact
[Name 1]	[Data-centre hosting / colocation]	[Country]	[N/A - EEA]	[email]
[Name 2]	[Managed database / backup]	[Country]	[Adequacy decision / SCCs Module 3]	[email]
[Name 3]	[Customer support tooling]	[Country]	[DPF certification and SCCs fallback]	[email]
[Name 4]	[Email delivery / monitoring]	[Country]	[ ]	[email]
[Affiliate: Provider Group entity]	[Follow-the-sun support]	[Country]	[Intra-group SCCs / BCRs]	[email]

Annex IV. International Transfers - Transfer Mechanisms and SCC Elections

1. Application of the SCCs

Where a Restricted Transfer takes place under Clause 10.2(b) of this DPA, the Parties agree that the Standard Contractual Clauses annexed to Commission Implementing Decision (EU) 2021/914 are incorporated by reference and apply as follows, with Annexes I to III of the SCCs completed by Annexes I to III of this DPA:

SCC element	Election
Module	**Module Two** (controller to processor) where the Customer is a controller; **Module Three** (processor to processor) where the Customer is a processor on behalf of a third-party controller. Where the Provider transfers to a Sub-processor outside the EEA, it shall enter Module Three clauses with that Sub-processor.
Clause 7 (docking clause)	Included
Clause 9(a) (use of sub-processors)	Option 2 - general written authorisation; notice period: [thirty (30)] days (as in DPA Clause 6.3)
Clause 11(a) (redress)	Optional independent dispute-resolution body language: [not included]
Clause 13(a) (supervisory authority)	The supervisory authority of the Member State in which the data exporter is established; where the exporter is not established in the EU but is subject to Article 3(2), the authority of the Member State of its representative; otherwise [Member State]
Clause 17 (governing law)	Option 1 (Module Two) / Option 1 (Module Three): the law of [Ireland / the Netherlands / another Member State that allows third-party beneficiary rights]
Clause 18(b) (forum)	The courts of [Member State, as in Clause 17]
Annex I.A and I.B	As per Annex I of this DPA
Annex I.C	Competent supervisory authority as in Clause 13(a)
Annex II	Technical and organisational measures in Annex II of this DPA
Annex III	List of Sub-processors in Annex III of this DPA (Option 2)

2. Supplementary measures

- Encryption of Customer Personal Data in transit and at rest, with keys managed in the EEA [by the Customer / by an EEA-based key-management service], so that the importer cannot access data in clear text except as the Customer enables.
- Access policy: no standing access from outside the EEA; any support access just-in-time, approved by the Customer, logged and reviewable.
- Pseudonymisation or tokenisation before transfer where the purpose allows.
- Government-access policy and transparency reporting as per Clause 10.5; commitment to challenge disproportionate requests.
- Regular review of the transfer impact assessment, at least annually, or on legal change; notification of any change that affects the assessment.

3. EU-US Data Privacy Framework

Where the importer is certified under the EU-US Data Privacy Framework and its certification covers the relevant data, the Parties may rely on the adequacy decision for the transfer. The importer shall maintain the certification during the Term, notify the Customer within [five (5)] days of any lapse, withdrawal or change in scope, and the SCCs apply automatically as a fallback as provided in Clause 10.3 of the DPA. The Parties note that the General Court upheld the adequacy decision in September 2025 and that an appeal is pending before the Court of Justice.

4. UK and Swiss transfers

For transfers subject to the UK GDPR, the UK International Data Transfer Addendum to the EU SCCs (Version B1.0, in force 21 March 2022) is incorporated, with the tables completed by reference to this DPA and either party

able to end the Addendum in accordance with its section 19. For transfers subject to the Swiss FADP, the SCCs apply with references to the GDPR read as references to the FADP, references to the competent supervisory authority as the Federal Data Protection and Information Commissioner, and 'Member State' not excluding data subjects in Switzerland from enforcing their rights in Switzerland.

> ***Drafting note:*** *Check the current status of any UK or EU adequacy decision for the relevant destination and the latest guidance of the EDPB and national authorities on transfer impact assessments before finalising this Annex.*